

Architecture — Server-Controlled Pilot Access

Planes

Control plane (Supabase): authentication identity, profiles, organization membership, customer + internal roles, pilot entitlements/status/dates/seats, invitations metadata, MFA enrollment metadata, account status, nonfinancial security/administrative events, login timestamps, revocation metadata. Nothing financial.

Data plane (browser-local): invoice/bank/remittance/delivery files, OCR contents, matching candidates, match results, allocations, posting exports. These are processed in the browser and never transmitted to Supabase during the core workflow.

Authentication & authorization flow

1. User signs in (email/password) via Supabase Auth.
2. TOTP MFA challenge → session reaches **AAL2**. AAL1 alone never authorizes real data.
3. Before real-data work, the app calls the **authorize-pilot-session** Edge Function, which invokes the SECURITY DEFINER SQL function `authorize_pilot_session()` **as the caller**. It checks, using the **server clock**: authenticated, AAL2, profile active, active membership, `org_pilot_active`, `entitlement_active`, and `pilot_start_at ≤ now < pilot_end_at`.
4. The decision returns `revalidate_after_seconds` ($≤ 300$). The app re-checks on that interval; a negative decision locks the session out (no Demo fallback) while preserving local workspace data.

Roles

Customer: `organization_admin`, `cash_application_manager`, `cash_application_analyst`, `reviewer`, `read_only`. **Internal (protected table, never in user metadata):** `armp_owner`, `armp_operations_admin`, `armp_support`, `armp_sales_read_only`. Privileged Edge Functions require `armp_owner/armp_operations_admin`; `support` + `sales_read_only` can view the dashboard but cannot mutate entitlements.

AAL usage

- **AAL1:** authenticated but MFA not yet satisfied → routed to enrollment/challenge; no real-data access, no privileged action.
- **AAL2:** MFA challenge completed this session → required for real-data access, Operations Console, and every privileged Edge Function (verified server-side immediately before the action).

Not built (Phase 3 completion + Phase 4)

Cleared-funds production activation gating, production Supabase project, production SMTP, backup/recovery validation, full modularization. These remain specifications.